

# Table of Contents

## CSW Compliance & Cyber-Insurance — SE Discovery Role-Play & Sample Script

Companion to the [CSW Compliance Mapping repository](#). This is an **enablement rehearsal aid** for Cisco SEs/SAs and partners — and a structure customers can use internally — for a first compliance-and-risk discovery conversation around Cisco Secure Workload (CSW). It is **not** a pitch to read verbatim, and it is **not** legal, audit, or insurance/underwriting advice. See the [disclaimer](#).

### How to use this

- **Rehearse, don't recite.** The dialogue models *discovery first, capability second*. Adapt names, sector, and frameworks to the account in front of you.
  - **Lead with the customer's words, not the product.** The goal of the first meeting is to leave with their compliance drivers, their cyber-insurance renewal timeline, and one or two segmentation/lateral-movement pains worth a proof-of-value — **not** to demo every feature.
  - **Stay honest about scope.** CSW is a workload-segmentation and workload-telemetry platform. It supports a *subset* of the controls auditors and underwriters ask about and **complements** identity (Duo/ISE), endpoint (Secure Endpoint/XDR), email, and backup controls rather than replacing them. Over-claiming on a compliance or insurance call is the fastest way to lose a CISO's trust.
  - **Map, then prove.** Every claim in the conversation should point to an artifact this repo already provides — a framework runbook, the [evidence playbook](#), or the [scope design guide](#).
- 

### The cast (fictional composite)

| Role                  | Name        | Cares about                                                    |
|-----------------------|-------------|----------------------------------------------------------------|
| Cisco SE              | <b>Alex</b> | Earning a POV; mapping pain to evidence; not over-promising    |
| CISO                  | <b>Dana</b> | Breach risk, board reporting, audit fatigue, insurance renewal |
| GRC / Compliance lead | <b>Sam</b>  | Audit evidence, control narratives, assessor questions         |

| Role                   | Name          | Cares about                                                      |
|------------------------|---------------|------------------------------------------------------------------|
| Risk / Finance (cameo) | <b>Jordan</b> | Cyber-insurance premium, coverage terms, ransomware supplemental |

*Setting: a mid-size financial-services firm (composite). Swap for a hospital network, manufacturer, SaaS provider, or agency as needed — the structure holds.*

---

## Pre-call prep (5 minutes that change the meeting)

Before you walk in, know:

1. **Which frameworks bind them.** Public co? → SOC 2, maybe PCI. Bank/insurer in NY? → **NY DFS 23 NYCRR 500**. EU financial entity? → **DORA**. Health? → **HIPAA** (and the 2025 NPRM's *proposed mandatory segmentation*). Card data? → **PCI DSS v4.0**. Map each to its folder in the [README asset library](#).
  2. **When their cyber-insurance renews.** Renewal season creates a hard deadline and a budget owner (Risk/Finance) who is not usually in security meetings.
  3. **What incident is on their mind.** A peer breach, a near-miss, a failed audit finding, or a painful insurance questionnaire — that is your real entry point.
- 

## Act 1 — Open by asking for their compliance needs

**Alex:** Before I say anything about Cisco, I'd like to understand what you're actually accountable for this year. If we walked your environment together, which obligations are top of mind — and which one is causing the most work right now?

**Sam:** Honestly? Evidence. We *pass* audits, but every cycle it's a fire-drill — screenshots, spreadsheet exports, network diagrams we hope still match reality. Our assessor keeps pushing on "show me segmentation is actually enforced, not just designed."

**Dana:** And our cyber-insurance renewal is in Q3. The supplemental application this year is brutal — pages of questions about segmentation, lateral movement, MFA, EDR, backups. Last year a peer got non-renewed.

**SE technique:** notice Alex didn't pitch. Two gold threads just surfaced — *audit evidence fatigue* and *an insurance deadline with a control questionnaire*. Both map to the same underlying capability. Pull on them.

## Discovery questions worth asking (pick 3–4, don't interrogate)

These mirror the five in [Why these mappings matter](#):

- "If your assessor asks you to **demonstrate least-privilege between two applications**, what artifact do you hand them today?" (SOC 2 CC6.1, NIST AC-3)

- "When a CVE drops in a library inside a production app, **how long until you know which workloads are exposed and what could reach them?**" (*NIST RA-5, CM-7*)
  - "Can you enumerate, right now, **every process talking to your regulated data environment** and how that changed over the last 30 days?" (*PCI 1.2, 11.5*)
  - "On your insurance supplemental, the segmentation and lateral-movement questions — are you answering those from **enforced policy** or from a **diagram and good intentions?**"
  - "If a tabletop asked *how fast can you change who talks to whom*, is the answer **continuous and policy-driven**, or a **network redesign project?**"
- 

## Act 2 — Connect the pain to capability (carefully)

**Alex:** It sounds like the recurring theme is *proving a control still holds — tomorrow, not just on audit day* — and answering the same question an incident responder or an underwriter asks: **who can talk to whom, and what changed?**

**Dana:** That's exactly it. The diagram says one thing; I can't swear the network matches it.

**Alex:** That gap is what Cisco Secure Workload is built to close at the workload layer. An agent on the host (or agentless ingestion) observes the *actual* conversations — process, port, direction — and turns that into a segmentation policy you **simulate before you enforce**, so you see what would break before it does. The same flow record that proves the control to your assessor is the record your IR team wants during an incident. I want to be clear though: CSW handles the **workload East-West** story. It doesn't do your MFA or your EDR — it sits *alongside* Duo, ISE, and Secure Endpoint.

**SE technique:** the honesty ("it doesn't do MFA/EDR") *builds* credibility and sets up the insurance mapping in Act 4, where you'll show which boxes CSW checks and which its siblings do.

**Sam:** So the policy and the evidence are the same object?

**Alex:** Right. You author intent in business terms —

```
ALLOW  app=payments      env=prod  ->  app=payments-db  env=prod
tcp/5432
DENY    env=nonprod       ->  app=payments  env=prod      (lateral)
```

— and the platform shows you the flows that match or violate it, on an ongoing basis. That export is your least-privilege artifact *and* your "what moved" answer.

---

## Act 3 — Frame it in their compliance language

Now translate to the specific framework(s) that bind them, using this repo's runbooks as the proof the mapping is real (not marketing):

| If they live under... | Lead with these controls | Repo asset                  |
|-----------------------|--------------------------|-----------------------------|
| <b>PCI DSS v4.0</b>   | CDE segmentation (Req    | <a href="#">PCI runbook</a> |

| If they live under...              | Lead with these controls                                                              | Repo asset                    |
|------------------------------------|---------------------------------------------------------------------------------------|-------------------------------|
|                                    | 1.2), scope reduction,<br>Req 11 testing inputs                                       |                               |
| <b>HIPAA / 2025 NPRM</b>           | ePHI isolation<br>§164.312(a)(1); NPRM's<br><i>proposed</i> mandatory<br>segmentation | <a href="#">HIPAA · NPRM</a>  |
| <b>SOC 2</b>                       | Continuous CC6.x<br>evidence vs point-in-<br>time samples                             | <a href="#">SOC 2 runbook</a> |
| <b>NIST 800-53 / CSF 2.0</b>       | AC-4 flow enforcement;<br>CA-7 continuous<br>monitoring                               | <a href="#">800-53 · CSF</a>  |
| <b>NY DFS 500 / MAS /<br/>APRA</b> | Covered-system<br>segmentation; third-<br>party egress; incident<br>support           | <a href="#">NY DFS</a>        |
| <b>DORA / NIS2</b>                 | Art. 9 / Art. 21<br>segmentation; incident<br>dossier timelines                       | <a href="#">DORA · NIS2</a>   |
| <b>Zero-trust mandate</b>          | CISA ZTMM Networks<br>pillar; 800-207 PEP<br>placement                                | <a href="#">ZTMM</a>          |

**Alex:** Whichever of these you're graded on, the underlying ask is the same control — enforced segmentation with living evidence. We have a control-by-control runbook for each so your GRC team sees the exact CSW step and the exact export, and your assessor sees something real. Start with the [evidence playbook](#); it's framework-agnostic.

## Act 4 — The cyber-insurance angle (the one everyone's feeling)

This is where Risk/Finance (**Jordan**) joins. Cyber-insurance applications and **ransomware supplemental questionnaires** have, across the market, converged on a recognizable control set. Being able to **answer them from enforced reality and exportable evidence** — rather than assertions — tends to make the application cleaner and the underwriter conversation shorter.

**Jordan:** Our broker says the carriers want proof, not checkboxes, this year. Where does this actually help our application?

**Alex:** Let me be precise about what CSW does and doesn't cover on a typical supplemental — because some of these belong to other controls.

## Cyber-insurance / ransomware supplemental — control-by-control honesty

| Typical questionnaire control                                      | Does CSW help?                 | How (or what to pair it with)                                                        |
|--------------------------------------------------------------------|--------------------------------|--------------------------------------------------------------------------------------|
| <b>Network segmentation</b> of critical/regulated systems          | <b>Directly</b>                | Core CSW: simulate → enforce micro-segmentation; exportable policy + flows           |
| <b>Restrict lateral movement</b> / contain ransomware blast radius | <b>Directly</b>                | East-West allow/deny; deny known ransomware propagation paths (SMB/RDP/WinRM)        |
| <b>Limit/monitor RDP, SMB, admin protocols</b>                     | <b>Directly</b>                | Discover exposed RDP/SMB East-West and deny or scope it; flag exposure               |
| <b>Asset &amp; software inventory</b>                              | <b>Supports</b>                | Workload + software package inventory feeds the inventory questions                  |
| <b>Vulnerability / patch management</b>                            | <b>Supports prioritization</b> | CVE + reachability/EPSS context to prioritize what's actually exposed                |
| <b>Logging &amp; monitoring of internal traffic</b>                | <b>Supports</b>                | Forensic-grade East-West flow history; export to SIEM (Splunk)                       |
| <b>Privileged access path control</b>                              | <b>Supports</b>                | Restrict which segments can reach management/admin planes                            |
| <b>MFA (remote access, privileged, email)</b>                      | <b>No — pair</b>               | Cisco <b>Duo</b> / <b>ISE</b> ; CSW does not provide MFA                             |
| <b>EDR / XDR on endpoints</b>                                      | <b>No — pair</b>               | Cisco <b>Secure Endpoint</b> / <b>XDR</b> ; CSW is workload telemetry, complementary |
| <b>Secured / immutable backups, tested restores</b>                | <b>No — pair</b>               | Backup tooling; CSW can <i>protect the path to</i> backup infrastructure             |
| <b>Email security / phishing controls</b>                          | <b>No — pair</b>               | Email security gateway                                                               |
| <b>Incident response plan &amp; forensics readiness</b>            | <b>Supports</b>                | CSW flow evidence shortens "what moved,                                              |

| Typical questionnaire control                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     | Does CSW help? | How (or what to pair it with) |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------|-------------------------------|
| what changed" during IR                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |                |                               |
| <p><b>Alex:</b> So on the segmentation, lateral-movement, RDP/SMB-exposure, internal-logging, and vuln-prioritization questions, we can help you answer from <b>enforced policy with evidence</b>. On MFA, EDR, backups, and email, you'll answer with your other controls — several of which are also Cisco, if useful. What we <b>don't</b> do is promise a premium outcome; that's the carrier's call. What we <i>can</i> do is make the application defensible and the back-and-forth shorter.</p> <p><b>Why this resonates "in these challenging times":</b> insurers have tightened because ransomware losses concentrate exactly where segmentation is weak — unbounded lateral movement turning one foothold into an enterprise event. The control underwriters now insist on is the same control your auditor wants and the same control your IR team needs. One investment, three audiences.</p> <p><b>Compliance honesty note.</b> Carrier requirements, coverage, and pricing vary by insurer and broker and change frequently. Nothing here is insurance or underwriting advice. Use this to <i>prepare evidence</i>, not to predict an outcome.</p> |                |                               |

## Act 5 — Close to a proof, not a purchase

**Alex:** Here's what I'd suggest. Pick **one** regulated application — your payments path, or whatever's on the audit *and* the insurance form. In a scoped POV we'll: deploy agents, let CSW learn the real conversations, draft a segmentation policy, run it in **simulate**, and produce a sample **evidence pack** — the same export you'd hand an assessor or attach to the insurance supplemental. You decide if the artifact is real before you enforce anything.

**Dana:** And if the simulation shows our diagram was wrong?

**Alex:** Then you found that out in a lab window instead of during an incident or an audit. That finding alone is usually worth the POV.

### Concrete next steps to leave on the table:

1. Share the [evidence playbook](#) and the runbook(s) for their binding framework(s).
2. Agree the **one application** and success criteria for the POV (use the [scope design guide](#)).
3. Get the **insurance renewal date** and the supplemental questionnaire; map its control questions to the table in Act 4.
4. Invite GRC (**Sam**) and Risk (**Jordan**) to the POV readout — the evidence pack is for all three.

## Objection handling (quick reference)

| Objection                    | A grounded response               |
|------------------------------|-----------------------------------|
| "We already have firewalls." | Perimeter firewalls govern North- |

| Objection                        | A grounded response                                                                                                                                                                                                                          |
|----------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                  | South; the insurance and audit questions are about <b>East-West</b> lateral movement between workloads. Different problem, same diagram gap.                                                                                                 |
| "We have EDR."                   | Good — keep it. EDR watches the endpoint; CSW watches <b>workload-to-workload</b> conversations and enforces who may talk to whom. They answer different questionnaire lines (Act 4).                                                        |
| "Isn't this just NSX / Illumio?" | Evaluate on three things: where enforcement lives, whether policy is <b>anchored in observed behavior</b> with simulate-before-enforce, and whether the evidence export survives an assessor's scrutiny. Run the POV and judge the artifact. |
| "Too complex / we're small."     | Start with one app and <b>simulate</b> — no enforcement risk. The output is an evidence pack; complexity is opt-in as you expand scope.                                                                                                      |
| "Will this lower our premium?"   | I won't promise that — it's the carrier's decision. I <i>can</i> make your segmentation and lateral-movement answers evidence-backed, which is what the supplemental is asking for.                                                          |
| "Compliance is just a checkbox." | The boxes encode real breach failure modes. The same control that checks the box contains the blast radius — that's the leading indicator when something goes wrong.                                                                         |

## Leave-behind checklist (send within 24h)

- ☐ Links: [README asset library](#), the binding-framework runbook(s), [evidence playbook](#).
- ☐ The **Act 4 control-mapping table** as their insurance-prep worksheet.
- ☐ One-paragraph POV scope (the single application + simulate-only + evidence pack).
- ☐ Calendar hold for the POV readout with **Security + GRC + Risk** present.

## Disclaimer

This role-play is **illustrative enablement material**, not a script to be read verbatim, and **not legal, regulatory, audit, or insurance/underwriting advice**. Personas and the scenario are

fictional composites. Cyber-insurance carrier requirements, coverage, and pricing vary by insurer and broker and change frequently; nothing here predicts or guarantees any insurance outcome, premium change, or coverage decision. Cisco Secure Workload supports a *subset* of common audit and insurance controls (notably segmentation, lateral-movement containment, East-West visibility/logging, workload/software inventory, and vulnerability prioritization) and **complements** — does not replace — identity/MFA (Duo/ISE), endpoint (Secure Endpoint/XDR), email security, and backup controls. All framework mappings referenced here require subject-matter-expert review against current official sources and your assessors before formal reliance; see the [repository disclaimer](#).

---

### See also

- [Compliance evidence playbook](#) — the 4-phase evidence programme this conversation leads into.
- [Framework scope design guide](#) — turn the agreed framework into CSW scopes and labels for the POV.
- [Why these mappings matter](#) — the five conversation-starter questions, expanded.
- [Repository README](#) — full asset library and disclaimer.